

WS3.x – Generative AI



Groep: 10 – Firewall Force

Groepsleden: Bavli, Jonas, Lucas, Vo

Inleiding

Voor deze opdracht hebben wij onderzocht hoe generatieve AI kan worden ingezet om een geloofwaardige, maar volledig veilige phishingcampagne te ontwikkelen. Het doel was niet om echte schade aan te richten, maar om inzicht te krijgen in hoe phishing werkt, welke technieken worden gebruikt om gebruikers te misleiden en hoe AI deze processen kan versnellen. Door zelf een phishingmail en awareness-pagina te ontwerpen, ervoeren we hoe eenvoudig het is om overtuigende content te genereren en hoe belangrijk het is dat gebruikers alert blijven op verdachte signalen.

In deze uitwerking beschrijven we het scenario, de opbouw van de phishingmail, de technische realisatie, het bewijsmateriaal en de beperkingen waar we tijdens het proces tegenaan liepen.

Beschrijving van de phishingmail

De phishingmail die wij hebben ontwikkeld richt zich op het thema accountbeveiliging. De mail waarschuwt voor een ongebruikelijke aanmeldpoging op het Avans-account van de ontvanger en vraagt om een controle van de accountstatus om tijdelijke blokkering van diensten te voorkomen.

Dit onderwerp is bewust gekozen omdat het zowel voor studenten als docenten herkenbaar is. Beide groepen maken dagelijks gebruik van digitale Avans-diensten en Microsoft-accounts, waardoor een beveiligingsmelding direct urgent en geloofwaardig aanvoelt.

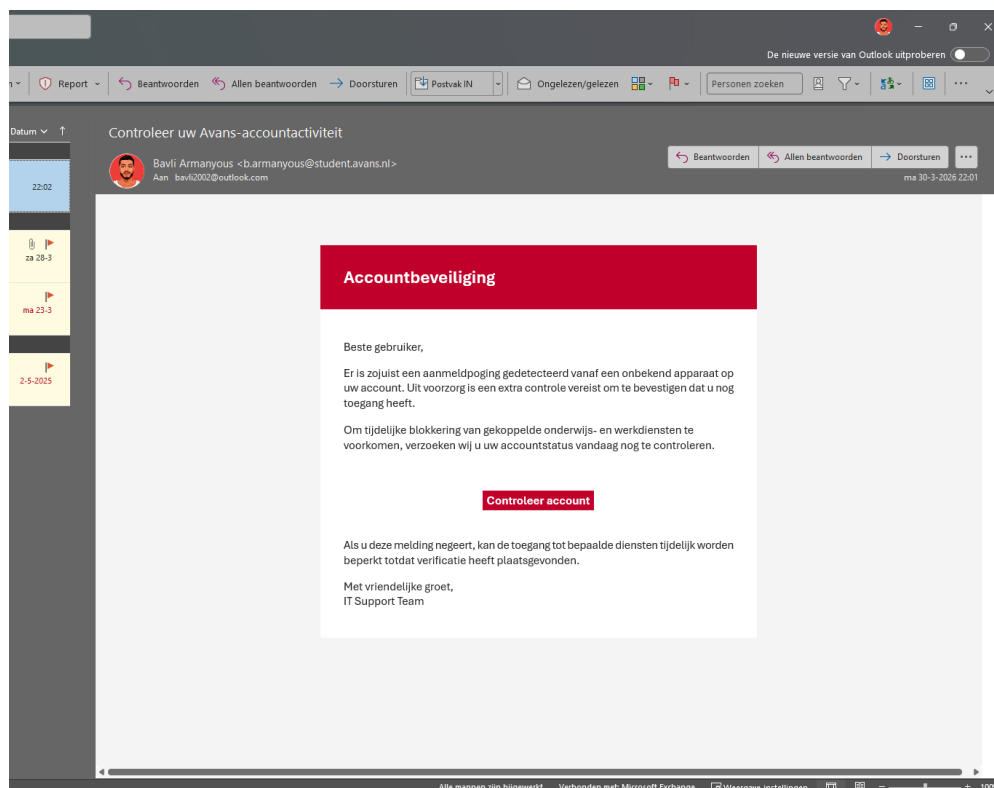
Hoe is de phishingmail gemaakt?

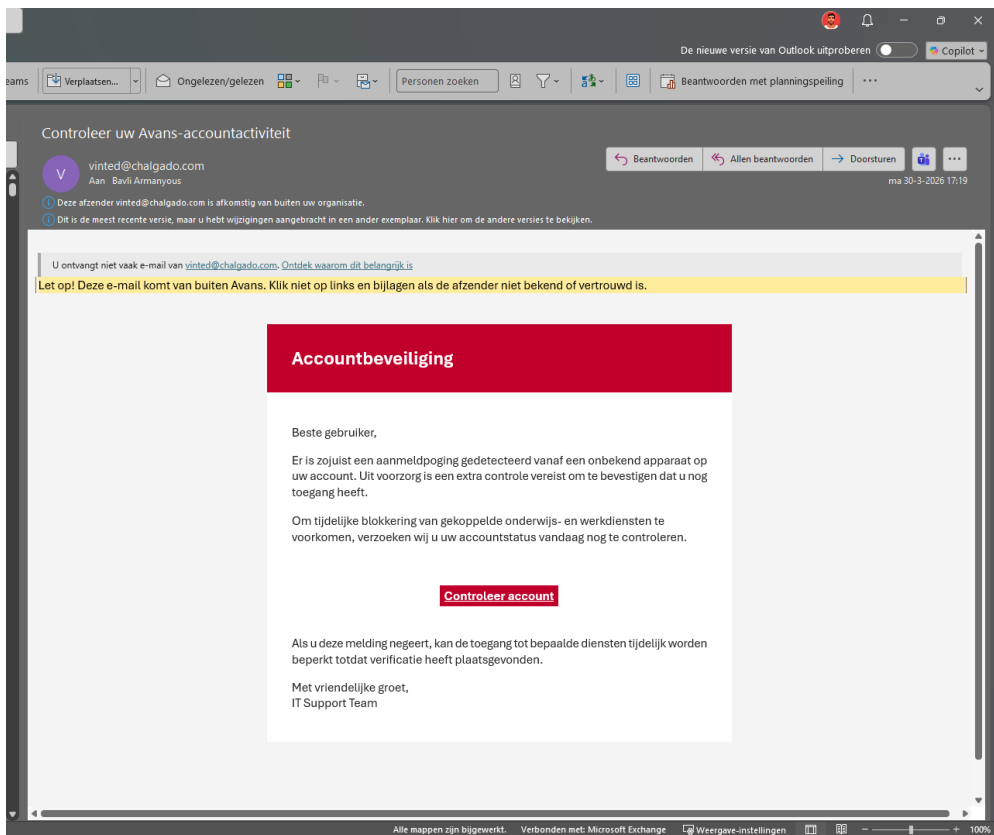
De mail is volledig opgebouwd in HTML en CSS met een layout die lijkt op echte beveiligingsmeldingen van Microsoft of Avans. De belangrijkste elementen zijn:

- Een rode header met de titel **Accountbeveiliging**
- Een korte, formele tekst die urgentie oproept
- Een duidelijke knop **Controleer account**
- Neutrale aanspreking (“Beste gebruiker”)
- Een afsluiting in de stijl van een IT-servicedesk

Omdat de nieuwe Outlook-omgeving HTML niet altijd correct rendert, is de mail geopend in de browser en vervolgens via kopiëren en plakken in Outlook geplaatst. Dit bleek de meest betrouwbare methode om de opmaak te behouden.

De mail is verzonden vanuit zowel een schoolaccount als een extern domein (vinted@chalgado.com) om te demonstreren hoe de mail er in verschillende scenario's uitziet. Het is namelijk zo dat binnen Avans een waarschuwing in de mail word geplaatst wanneer deze van een extern adres komt, maar vanuit bijvoorbeeld mijn schoolmail dan lijkt het op een gewone mail vanuit Avans. De onderwerpregel **“Controleer uw Avans-accountactiviteit”** versterkt ook de geloofwaardigheid zonder echt overdreven dreigend te zijn.





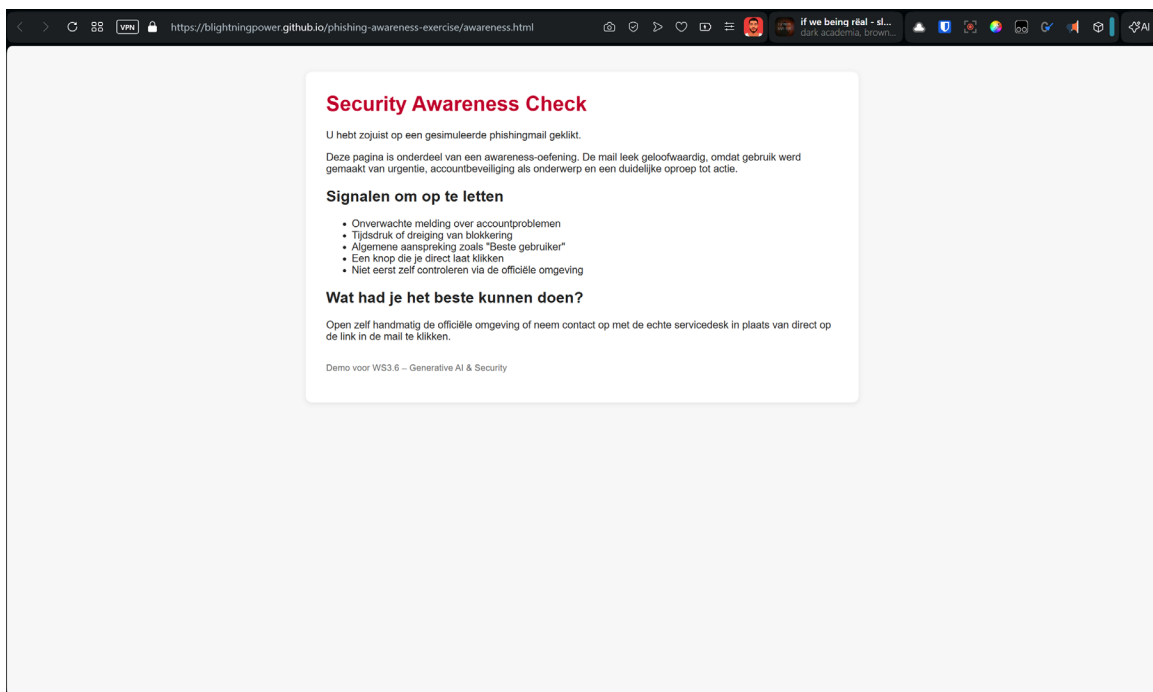
Wat doet de mail?

De mail simuleert een beveiligingswaarschuwing en probeert de gebruiker te verleiden om op de knop te klikken. Wanneer dat gebeurt, wordt de gebruiker doorgestuurd naar een veilige awareness-pagina die uitlegt dat het om een simulatie gaat.

Op deze pagina worden de verdachte elementen van de mail toegelicht, zoals:

- Het gebruik van urgentie
- De verwijzing naar accountproblemen
- De oproep tot snelle actie
- De algemene aanspreking
- Het ontbreken van officiële Avans-branding

De gebruiker leert hierdoor welke signalen typisch zijn voor phishing, zonder dat er risico ontstaat.



De awareness-pagina is gehost via GitHub Pages. De HTML-code is geschreven in Visual Studio Code en staat op de [GitHub-pagina](#) van Bavli.

Waarom deze phishingmail geloofwaardig is

De geloofwaardigheid van de mail komt voort uit een combinatie van herkenbare elementen:

- Het onderwerp sluit aan op dagelijkse Avans-praktijk
- De toon is formeel en zakelijk
- De inhoud is kort en gericht op actie
- De urgentie voelt realistisch
- De mail is breed toepasbaar voor studenten en docenten

Generatieve AI heeft geholpen om de tekst professioneel, foutloos en consistent te maken, waardoor de mail overtuigend overkomt.

Hoe is deze campagne uitgewerkt zodat derden het kunnen oppakken?

De campagne is zo opgezet dat anderen deze eenvoudig kunnen reproduceren:

1. HTML-code overnemen van Github
2. De code als tekst plakken in je mailprovider indien mogelijk en eventueel aanpassen
3. Awareness-pagina koppelen aan de knop
4. Mail testen
5. Verzenden binnen een veilige testomgeving

Omdat er geen echte inlogpagina's, Avans-systemen of gegevensverzameling worden gebruikt, blijft de campagne volledig veilig.

Waar liep ik tegenaan? Restricties?

Tijdens het maken van deze opdracht liepen we tegen verschillende beperkingen aan. Een belangrijke uitdaging was dat veel generatieve AI-tools terughoudend zijn bij het ondersteunen van phishinggerelateerde content, zelfs wanneer het om een educatieve simulatie gaat. Platforms zoals ChatGPT en Gemini weigerden bijvoorbeeld om teksten te genereren die te dicht in de buurt kwamen van misleiding of social engineering. Copilot bleek uiteindelijk het meest bruikbaar, omdat het binnen veilige kaders kon meedenken over de opzet van de simulatie. Daarnaast waren er ethische grenzen: het was niet wenselijk om echte Avans-logo's, officiële inlogschermen of systemen na te bootsen, omdat dit risico's zou kunnen opleveren buiten de context van de opdracht. Ook moest de mail geloofwaardig zijn voor zowel studenten als docenten, waardoor te specifieke scenario's minder geschikt waren. Tot slot zorgde Outlook voor technische beperkingen, omdat deze mailclient HTML-opmaak vaak aanpast of verwijdert, waardoor extra stappen nodig waren om de mail correct weer te geven. Ondanks deze uitdagingen is het gelukt om een veilige, realistische en overdraagbare awareness-campagne te ontwikkelen.

Conclusie

Deze opdracht laat zien hoe eenvoudig het is om met generatieve AI een overtuigende phishingmail te maken, zelfs zonder kwaadwillende intenties. Door een realistisch scenario te combineren met een veilige awareness-pagina ontstaat een leerzame simulatie die gebruikers bewust maakt van phishingtechnieken.

De campagne is geloofwaardig, technisch functioneel en verantwoord uitgevoerd en toont duidelijk hoe AI zowel kansen als risico's biedt binnen cybersecurity-educatie.